

****New Decision****

The Data Protection Agency expresses serious criticism in the case concerning the breakdown of NemID

Date: 02-05-2024

****Decision****

Private Companies

Serious Criticism

Supervision / Own Initiative Case

Processing Security

The Data Protection Agency has made a decision in a case regarding the breakdown of NemID in June 2022, where up to 1.5 million NemID users experienced problems using NemID.

Journal Number: 2023-432-0017.

****Summary****

For four days, the affected users could not access major public Danish services such as borger.dk, e-Boks, sundhed.dk, and minretssag.dk when logging in with NemID. Nets DanID A/S, which was the data controller at the time of the incident, followed their emergency procedure in an attempt to restore normal operations by restoring a server with a backup solution. However, it was not possible for Nets DanID A/S to restore normal operations until four days after the breakdown, as the backup solution was unavailable. The test of the emergency procedure, which could have identified the reason for the unavailability of the backup solution, was last conducted approximately two years prior to the breakdown. The Data Protection Agency has concluded in the case that Nets DanID A/S's procedures regarding testing, assessment, and evaluation of the effectiveness of the backup solution were insufficient. Furthermore, the Data Protection Agency assessed that Nets DanID A/S had not taken adequate measures to ensure the ongoing robustness of the NemID solution. On this basis, the Data Protection Agency has expressed serious criticism of Nets DanID A/S for not having sufficient measures to achieve a security level that was appropriate to the risks posed to citizens.

The Data Protection Agency has placed particular emphasis on the fact that this involved critical national infrastructure, and that the breakdown could therefore potentially have significant consequences for the affected citizens—especially considering the long duration of the breakdown. NemID was phased out on October 31, 2023, after which it was no longer possible to obtain and use NemID. MitID was launched in 2021 and has replaced NemID. However, the content of the decision regarding particular robustness and, in that connection, testing of backup and restoration remains relevant for data controllers and data processors concerning other solutions, especially when it involves critical national infrastructure.

****Testing of Backup and Restoration****

The requirements of the Data Protection Regulation regarding appropriate security will normally imply that backup testing should be conducted. This means that it should be regularly tested whether backups are performed at the expected intervals (frequency) and whether the backup copy is accessible, contains all relevant data (scope), and is accurate (integrity). In addition, restoration testing should be conducted, where it is tested whether data can actually be reloaded and used in an IT system. This is a test of (1) whether restoration can be performed with existing guidelines/procedures, (2) that everything that has been copied (hardware, software, data) can function together, and (3) that restoration can occur quickly enough in relation to the fact that the consequences typically increase over time (Recovery Time Objective).

1. **Introduction**

The Data Protection Agency hereby returns to the case, where the Data Protection Agency initiated an investigation on its own initiative on January 18, 2023, regarding a breakdown of NemID in June 2022. Following media coverage, the Data Protection Agency became aware that there was a breakdown of NemID in June 2022, which resulted in a significant portion of NemID users experiencing problems accessing NemID from June 21 to June 26, 2022, which meant that users could not access major public Danish services.

2. ****Decision****

After reviewing the case, the Data Protection Agency finds grounds to express serious criticism of Nets DanID A/S's (hereinafter Nets DanID) processing of personal data not being in accordance with the rules in the Data Protection Regulation's[1] Article 32, Section 1.

Below follows a detailed review of the case and a justification for the Data Protection Agency's decision.

3. ****Case Presentation****

3.1.

It emerged from the media coverage regarding the NemID breakdown that it was not possible for the affected citizens to access services such as borger.dk, e-Boks, and sundhed.dk, and that some lawyers could not access the digital court case portal, minretssag.dk.[2]

Prior to the Data Protection Agency's initiation of the investigation, Plesner Law Firm (hereinafter Plesner) had contacted the Data Protection Agency on behalf of Nets DanID on June 24, July 4, and September 14, 2022, with a description of the incident and information about an analysis describing the cause of the breakdown in NemID. Plesner stated in this connection that the analysis did not give rise to changing Nets DanID's assessment that there had been no breach of personal data security at Nets DanID.

By letter dated January 18, 2023, to Nets DanID, the Data Protection Agency informed the company of the initiation of the investigation on its own initiative and simultaneously requested the company to answer a number of questions.

Plesner then provided a statement on behalf of Nets DanID on March 1, 2023. In this context, Plesner submitted Nets DanID's emergency procedure called "Disaster Recovery Procedure" and a copy of the documentation for the test of the procedure that was conducted on June 21, 2022.

By letter dated March 31, 2023, the Data Protection Agency then requested Nets DanID to answer a number of additional questions. The Data Protection Agency subsequently received a statement from Plesner on April 28, 2023, which responded to the supervisory authority's questions on behalf of Nets DanID. At the time of the incident, Nets DanID was the data controller regarding the administration of the NemID solution. This follows from section 2.1.1 of the general remarks to the proposal for a law on the issuance of NemID with public digital signature for individuals and for employees of legal entities.[3] The law on the issuance of NemID with public digital signature for individuals and for employees of legal entities[4] was repealed on January 1, 2024.[5] NemID was shut down on October 31, 2023, after which it was no longer possible to obtain and use NemID.[6] MitID was launched in 2021 and has replaced NemID.[7]

3.2. Plesner has confirmed that Nets DanID was the data controller at the time of the incident for the processing of personal data related to the administration and decision-making regarding the issuance and blocking of NemID with public digital signature for individuals and for employees of legal entities.[8] Plesner has further stated that the outage was caused by human error in connection with a change to the server infrastructure on June 21, 2022. System data was overwritten during the implementation of the change, which resulted in the inability to restart the server that was used for updating the block list. Plesner has indicated that personal data was not overwritten or deleted, but that the error resulted in new valid block lists not being able to be created, signed, and timestamped. According to Plesner, the outage only affected one server (the ICA03 server), which had fewer valid certificates, as the server at that time was no longer issuing certificates. Plesner has stated that the block list contained information about all OCES certificates that were invalidated (blocked) in the period before automatic expiration three years after the issuance date. The block list contained two types of personal data: a certificate serial number and a timestamp for it, and the list thus described the officially blocked certificates.

Regarding the consequences of the outage, Plesner has stated that some service providers had chosen to validate the validity of certificates by checking against the block list to ensure that users with a blocked NemID could not log in to the service provided by the service provider. Plesner has indicated that the service providers themselves were responsible for implementing security measures related to

the choice of validating certificates and using NemID as a login solution for their service. These service providers could not perform such a check against the block list, as the block list was no longer valid due to the expired timestamp. This meant that no users with certificates on the server affected by the outage could log in to the service provider's service, even though the user had a valid OCES certificate that was not blocked and therefore did not appear on the block list.

The Data Protection Authority has understood from Plesner's statement that the affected certificates on the relevant server included personal certificates for individuals, employee certificates, function certificates, and company certificates. Another server (the ICA04 server) was, according to Plesner, not affected by the error, and this server at that time handled the block list for approximately $\frac{3}{4}$ of all valid NemID certificates. Plesner has provided a summary of how many certificates were affected by the outage. Regarding the personal certificates issued to individuals, it appears that 22 percent of them (approximately 1.2 million certificates) were issued by the ICA03 server and were therefore affected by the outage. The certificates issued as employee, function, and company certificates by the ICA03 server accounted for 25 percent (approximately 300,000 certificates). It further appears that 23 percent of all valid NemID certificates were affected by the outage, as they were issued by the ICA03 server.

Plesner has stated that for the service providers that did not choose to validate the validity of the certificates by checking against the block list, users would, despite the lack of an updated block list, be able to log in with NemID to the service of the respective service provider. In this context, Plesner further stated that Nets DanID issued and blocked certificates, but that they had no influence over which services the certificates could be used to log in to, or the manner in which NemID was integrated into the service. Therefore, according to Plesner, Nets DanID was not able to specify which public services were affected by the outage.

It appears from Plesner's statement that Nets DanID implemented a "Mini CA" server as a workaround solution on June 25, 2022 – i.e., four days after the outage on June 21, 2022 – with further changes on June 26, 2022, which resulted in the ICA03 block lists being updated and valid again. Nets DanID was simultaneously working on a permanent solution, and on July 7, 2022, a change was implemented that restored the standard environment on the ICA03 server.

3.3. Regarding the impact of the outage on MitID, Plesner has stated that there was no technical connection between NemID and MitID. Therefore, MitID was not directly affected by the outage in NemID. [A part of the section has been omitted]. In this context, Plesner has stated that the Agency for Digitization is the data controller for the processing of personal data, relating to the handling of these tasks, and that Nets DanID is the data processor.

3.4. Plesner has stated that Nets DanID had a change management process aimed at ensuring that changes are reviewed or tested, and that any errors or deficiencies are corrected before they are put into production. In relation to the change that led to the outage in NemID, it was not required under the change management process to test the specific type of change. According to Nets DanID's change management procedure, some changes were to be tested, while other types of changes were to be reviewed before being put into production. The change that led to the outage in NemID was, according to Plesner, reviewed and approved by a different employee than the one who implemented the change, and the change management procedure was correctly followed. Plesner has further stated that there were no errors in the change management procedure or in the description of the procedure for implementing the specific change on the server infrastructure. The human error occurred in the execution of the implementation of the specific change, as the execution deviated from the implementation procedure (step plan). Plesner has also indicated that testing the specific change would not have prevented the outage, as it would have led to the same result as the reviews that were conducted. Testing or reviewing the specific change could not, according to Plesner, have detected the human error in the execution of the implementation procedure for the change.

3.5. Plesner has stated that the reason it was not possible to restore normal operations earlier was that Nets DanID's backup solution, which Nets DanID attempted to use to restore the server, was unavailable due to a lack of a so-called [information omitted] for the specific server, which affected the

restoration procedure. It is evident from the case that Nets DanID had established an emergency procedure that described the process for handling system outages. This process was followed in relation to the missing update of the block list in June 2022. In this context, Nets DanID noted that the backup solution on the specific server was missing a [information omitted], and therefore the backup solution did not work. Furthermore, it appears that the emergency procedure for the specific part of NemID, where a file was missing in the backup solution, was tested approximately two years prior to the outage. Nets DanID conducted a test of the emergency procedure in another part of NemID in March 2022. In this context, Plesner has stated that on June 21, 2022, a test of the procedure was conducted. This test had already been scheduled to take place on this date prior to the outage, and the test was carried out before the outage. The test was conducted on a pre-production server, where [information omitted] was not missing. However, [information omitted] was missing on the production server. Therefore, the missing [information omitted] on the production server was not uncovered by the test. The purpose of the test on June 21, 2022, was according to Plesner to verify that the procedure worked and to train the team in following the procedure.

3.6. Plesner has stated that as a consequence of the outage, Nets DanID took a number of measures to prevent similar outages in the future. It is evident from the listing of measures that Nets DanID, among other things, introduced a process for regular testing of backup restoration in the production environment. It is further noted that data storage layers between ICA and CA data storage and system data storage were separated. Additionally, the replication of backups to another data center was monitored, and backups were restored once a month to ensure that it was possible to restore backups, including [information omitted]. A fourth measure concerned an improvement of the regular process for restoration testing of database backups in the production environment. Plesner has stated that continuous monitoring of the availability of [information omitted] on the production server was implemented, as well as ongoing testing to ensure that restoration from the backup solution was possible. Plesner has indicated that this reduced the risk of a backup not being restorable. In relation to this measure, Plesner has stated that a "HW snapshot" of the servers was also implemented, which made it possible to restore a server significantly faster than through the original emergency procedure. Thus, there were two alternative methods for restoring a server affected by an outage, such as the one that occurred in June 2022.

3.7. Plesner has noted that it is their assessment that the error did not lead to a breach of personal data security at Nets DanID. In this connection, Plesner has stated that the NemID solution contained a logical protection against an outdated block list being used in operations. Therefore, according to Plesner, there has not been any processing of outdated or incorrect information, and the processing was deliberately blocked to prevent this. Finally, Plesner has stated that Nets DanID has reported the outage in NemID to the Danish Agency for Digitization in accordance with Article 19 of the eIDAS Regulation. It follows from Article 19, paragraph 2, first sentence of the eIDAS Regulation, that qualified and non-qualified trust service providers that detect a breach of security or loss of integrity that has a significant impact on the provided trust service or the affected personal data must do so as soon as possible.

and in any case within 24 hours after becoming aware of the situation, must notify the supervisory authority, and possibly other relevant bodies such as the competent national authority for information security or the data protection authority. The Danish Agency for Digitisation is the supervisory authority in Denmark in the area of the eIDAS Regulation.[10]

4. Justification for the Data Protection Authority's Decision

The Data Protection Authority bases its decision on the fact that the blacklist on the server affected by the outage could not be used by service providers to validate the validity of certificates. The outage therefore resulted in approximately 25 percent of NemID users being unable to use NemID to log into services where the service provider had chosen to validate the validity of certificates against the blacklist for four days. The Data Protection Authority further establishes that Nets DanID's backup solution on the affected server was unavailable, and that Nets DanID had last tested the emergency procedure for the part of NemID where a file was missing in the backup solution approximately two

years prior to the outage.

It follows from Article 32, paragraph 1 of the General Data Protection Regulation that the data controller must take appropriate technical and organizational measures to ensure a level of security appropriate to the risks arising from the data controller's processing of personal data.

Thus, the data controller has an obligation to identify the risks that its processing poses to the data subjects and to ensure that appropriate security measures are implemented to protect the data subjects against these risks.

Furthermore, it follows from Article 32, paragraph 1, letters b and d, that the data controller, in this context – and depending on what is relevant – must, among other things, implement measures to maintain the ability to ensure ongoing confidentiality, integrity, availability, and resilience of processing systems and services, as well as implement procedures for regular testing, assessment, and evaluation of the effectiveness of the technical and organizational measures to ensure processing security.

Resilience aims, among other things, to ensure the technical and organizational robustness of processing systems and services, for example, by protecting them against harmful incidents.

It is the Data Protection Authority's opinion that the requirement in Article 32 for appropriate security will normally imply that backup testing should be conducted. This means that it should be regularly tested whether backups are performed at the expected intervals (frequency), whether the backup copy is available, contains all relevant data (scope), and is accurate (integrity).

Furthermore, restoration testing should also be conducted. In this context, it should be tested whether data can actually be reloaded and used in an IT system. This is a test of (1) whether restoration can be performed using existing guidelines/procedures, (2) that everything that has been copied (hardware, software, data) can work together, and (3) that restoration can occur quickly enough, as the consequences typically increase over time (Recovery Time Objective). This can be performed as an actual so-called "Disaster Recovery Test." It is essential that necessary system files can also be restored.

Since Nets DanID's backup solution was unavailable, resulting in the inability to restore normal operations before June 25, 2022 – four days after the outage – it is the Data Protection Authority's assessment that Nets DanID did not take sufficient measures to ensure ongoing resilience of Nets DanID's processing systems and services.

Furthermore, it is the Data Protection Authority's assessment that the procedures Nets DanID had implemented regarding testing, assessment, and evaluation of the effectiveness of the backup solution were not sufficient.

On this basis, the Data Protection Authority finds that Nets DanID did not take appropriate technical and organizational measures to ensure a level of security appropriate to the risks associated with Nets DanID's processing of personal data on the affected server that was subject to the outage.

The Data Protection Authority therefore expresses serious criticism that Nets DanID's processing of personal data did not occur in accordance with Article 32, paragraph 1 of the General Data Protection Regulation.

In assessing the case, the Data Protection Authority has particularly emphasized that it involved critical national infrastructure. The outage could therefore potentially have significant consequences for the citizens who, for several days, were unable to access the services affected by the outage, such as borger.dk, e-Boks, minretssag.dk, and sundhed.dk.

Additionally, the outage could potentially have consequences for citizens if businesses or public authorities were unable to access larger Danish services in connection with handling matters concerning these citizens, for example, in relation to cases and case information where immediate access to the information was necessary.

The Data Protection Authority has noted that Nets DanID implemented ongoing monitoring of the availability of [information omitted] on the production server and ongoing testing to ensure that recovery from the backup solution could occur after the outage. The Data Protection Authority has also noted that Nets DanID implemented an "HW snapshot" of the servers, which according to Plesner made it possible to restore a server significantly faster than through the original Disaster Recovery procedure.

[1] Regulation (EU) 2016/679 of the European Parliament and of the Council of April 27, 2016, on the protection of natural persons in relation to the processing of personal data.

personal data and on the free exchange of such data and on the repeal of Directive 95/46/EC (General Data Protection Regulation).

[2] This was indicated in an article on dr.dk dated November 22, 2022: <https://www.dr.dk/nyheder/indland/et-monument-over-inkompetence-rapport-afsloerer-alvorlige-sikkerhedsfejl-foer>

[3] Proposal for a Law on the issuance of NemID with public digital signature to individuals and to employees in legal entities, presented on February 22, 2018 (2017/1 LSF 150).

[4] Law No. 439 of May 8, 2018 on the issuance of NemID with public digital signature to individuals and to employees in legal entities.

[5] It follows from Executive Order No. 1376 of November 27, 2023 on the repeal of the law on the issuance of NemID with public digital signature to individuals and to employees in legal entities.

[6] It is stated on borger.dk

<https://www.borger.dk/hjaelp-og-vejledning/hvad-har-du-brug-for-hjaelp-til-NemID> and on the website of the Agency for Digitization: <https://digst.dk/it-loesninger/mitid/forgaengeren-til-mitid/>

[7] It is stated on the website of the Agency for Digitization: <https://digst.dk/it-loesninger/mitid/om-mitid/>

[8] Plesner has referred to § 1, subsection 2, of the then applicable Executive Order No. 899 of June 21, 2018 on the issuance and blocking of NemID with public digital signature to individuals and to employees in legal entities.

[9] Regulation (EU) No. 910/2014 of the European Parliament and of the Council of July 23, 2014 on electronic identification and trust services for electronic transactions in the internal market and repealing Directive 1999/93/EC

[10] It follows from § 2 of Law No. 617 of June 8, 2016 on supplementary provisions to the regulation on electronic identification and trust services for electronic transactions in the internal market.